

Another challenge is that portable end-user devices will periodically join a network and then disappear, making the inventory of currently available assets very dynamic. Likewise, cloud environments and virtual machines can be difficult to track in asset inventories when they are shut down or paused.

Another benefit of complete enterprise asset management is supporting incident response, both when investigating the origination of network traffic from an asset on the network and when identifying all potentially vulnerable, or impacted, assets of similar type or location during an incident.

Procedures and tools

This CIS Control requires both technical and procedural actions, united in a process that accounts for, and manages the inventory of, enterprise assets and all associated data throughout its life cycle. It also links to business governance through establishing data/asset owners who are responsible for each component of a business process. Enterprises can use large-scale, comprehensive enterprise products to maintain IT asset inventories. Smaller enterprises can leverage security tools already installed on enterprise assets or used on the network to collect this data. This includes doing a discovery scan of the network with a vulnerability scanner; reviewing anti-malware logs, logs from endpoint security portals, network logs from switches, or authentication logs; and managing the results in a spreadsheet or database.

Maintaining a current and accurate view of enterprise assets is an ongoing and dynamic process. Even for enterprises, there is rarely a single source of truth, as enterprise assets are not always provisioned or installed by the IT department. The reality is that a variety of sources need to be “crowd-sourced” to determine a high-confidence count of enterprise assets. Enterprises can actively scan on a regular basis, sending a variety of different packet types to identify assets connected to the network. In addition to asset sources mentioned above for small enterprises, larger enterprises can collect data from cloud portals and logs from enterprise platforms such as: Active Directory (AD), Single Sign-On (SSO), Multi-Factor Authentication (MFA), Virtual Private Network (VPN), Intrusion Detection Systems (IDS) or Deep Packet Inspection (DPI), Mobile Device Management (MDM), and vulnerability scanning tools. Property inventory databases, purchase order tracking, and local inventory lists are other sources of data to determine which devices are connected. There are tools and methods that normalize this data to identify devices that are unique among these sources.

For cloud-specific guidance, refer to the CIS Controls Cloud Companion Guide:
<https://www.cisecurity.org/controls/resources?crc=environment-specific-guidance>

For tablet and smart phone guidance, refer to the CIS Controls Mobile Companion Guide:
<https://www.cisecurity.org/controls/resources?crc=environment-specific-guidance>

For IoT guidance, refer to the CIS Controls Internet of Things Companion Guide:
<https://www.cisecurity.org/controls/resources?crc=environment-specific-guidance>

For Industrial Control Systems (ICS) guidance, refer to the CIS Controls ICS Implementation Guide:
<https://www.cisecurity.org/controls/resources?crc=environment-specific-guidance>

Safeguards

Safeguard 1.1: Establish and Maintain Detailed Enterprise Asset Inventory

Asset Type:	Devices	Security Function:	Identify	IG1	IG2	IG3
-------------	---------	--------------------	----------	-----	-----	-----

Establish and maintain an accurate, detailed, and up-to-date inventory of all enterprise assets with the potential to store or process data, to include: end-user devices (including portable and mobile), network devices, non-computing/IoT devices, and servers. Ensure the inventory records the network address (if static), hardware address, machine name, enterprise asset owner, department for each asset, and whether the asset has been approved to connect to the network. For mobile end-user devices, MDM type tools can support this process, where appropriate. This inventory includes assets connected to the infrastructure physically, virtually, remotely, and those within cloud environments. Additionally, it includes assets that are regularly connected to the enterprise’s network infrastructure, even if they are not under control of the enterprise. Review and update the inventory of all enterprise assets bi-annually, or more frequently.

Safeguard 1.2: Address Unauthorized Assets

Asset Type:	Devices	Security Function:	Respond	IG1	IG2	IG3
-------------	---------	--------------------	---------	-----	-----	-----

Ensure that a process exists to address unauthorized assets on a weekly basis. The enterprise may choose to remove the asset from the network, deny the asset from connecting remotely to the network, or quarantine the asset.

Safeguard 1.3: Utilize an Active Discovery Tool

Asset Type:	Devices	Security Function:	Detect	IG2	IG3
-------------	---------	--------------------	--------	-----	-----

Utilize an active discovery tool to identify assets connected to the enterprise’s network. Configure the active discovery tool to execute daily, or more frequently.

Safeguard 1.4: Use Dynamic Host Configuration Protocol (DHCP) Logging to Update Enterprise Asset Inventory

Asset Type: Devices	Security Function: Identify	IG2 IG3
----------------------------	------------------------------------	-----------------------

Use DHCP logging on all DHCP servers or Internet Protocol (IP) address management tools to update the enterprise’s asset inventory. Review and use logs to update the enterprise’s asset inventory weekly, or more frequently.

Safeguard 1.5: Use a Passive Asset Discovery Tool

Asset Type: Devices	Security Function: Detect	IG3
----------------------------	----------------------------------	------------

Use a passive discovery tool to identify assets connected to the enterprise’s network. Review and use scans to update the enterprise’s asset inventory at least weekly, or more frequently.

CONTROL 2

Inventory and Control of Software Assets

Safeguards: 7	IG1: 3/7	IG2: 6/7	IG3: 7/7
---------------	----------	----------	----------

Overview

Actively manage (inventory, track, and correct) all software (operating systems and applications) on the network so that only authorized software is installed and can execute, and that unauthorized and unmanaged software is found and prevented from installation or execution.

Why is this Control critical?

A complete software inventory is a critical foundation for preventing attacks. Attackers continuously scan target enterprises looking for vulnerable versions of software that can be remotely exploited. For example, if a user opens a malicious website or attachment with a vulnerable browser, an attacker can often install backdoor programs and bots that give the attacker long-term control of the system. Attackers can also use this access to move laterally through the network. One of the key defenses against these attacks is updating and patching software. However, without a complete inventory of software assets, an enterprise cannot determine if they have vulnerable software, or if there are potential licensing violations.

Even if a patch is not yet available, a complete software inventory list allows an enterprise to guard against known attacks until the patch is released. Some sophisticated attackers use “zero-day exploits,” which take advantage of previously unknown vulnerabilities that have yet to have a patch released from the software vendor. These software design flaws provide zero days for developers to fix these issues before attackers are able to exploit them. Depending on the severity of the exploit, an enterprise can implement temporary mitigation measures to guard against attacks until the patch is released.

Management of software assets is also important to identify unnecessary security risks. An enterprise should review its software inventory to identify any enterprise assets running software that is not needed for business purposes. For example, an enterprise asset may come installed with default software that creates a potential security risk and provides no benefit to the enterprise. It is critical to inventory, understand, assess, and manage all software connected to an enterprise’s infrastructure.

Procedures and tools

Allowlisting can be implemented using a combination of commercial allowlisting tools, policies, or application execution tools that come with anti-malware suites and popular operating systems. Commercial software inventory tools are widely available and used in many enterprises today. The best of these tools provides an inventory check of hundreds of common software used in enterprises. The tools pull information about the patch level of each installed program to ensure that it is the latest version and leverage standardized application names, such as those found in the Common Platform Enumeration (CPE) specification.

Features that implement allowlists are included in many modern endpoint security suites and even natively implemented in certain versions of major operating systems. Moreover, commercial solutions are increasingly bundling together anti-malware, anti-spyware, personal firewall, and host-based IDS and Intrusion Prevention System (IPS), along with application allow and block listing. In particular, most endpoint security solutions can look at the name, file system location, and/or cryptographic hash of a given executable to determine whether the application should be allowed to run on the protected machine. The most effective of these tools offer custom allowlists based on executable path, hash, or regular expression matching. Some even include a non-malicious, yet unapproved, applications function that allows administrators to define rules for execution of specific software for certain users and at certain times of the day.

For cloud-specific guidance, refer to the CIS Controls Cloud Companion Guide:
<https://www.cisecurity.org/controls/resources?crc=environment-specific-guidance>

For tablet and smart phone guidance, refer to the CIS Controls Mobile Companion Guide:
<https://www.cisecurity.org/controls/resources?crc=environment-specific-guidance>

For IoT guidance, refer to the CIS Controls Internet of Things Companion Guide:
<https://www.cisecurity.org/controls/resources?crc=environment-specific-guidance>

For Industrial Control Systems (ICS) guidance, refer to the CIS Controls ICS Implementation Guide:
<https://www.cisecurity.org/controls/resources?crc=environment-specific-guidance>

Safeguards

Safeguard 2.1: Establish and Maintain a Software Inventory

Asset Type: Software	Security Function: Identify	IG1	IG2	IG3
-----------------------------	------------------------------------	------------	------------	------------

Establish and maintain a detailed inventory of all licensed software installed on enterprise assets. The software inventory must document the title, publisher, initial install/use date, and business purpose for each entry; where appropriate, include the Uniform Resource Locator (URL), app store(s), version(s), deployment mechanism, decommission date, and number of licenses. Review and update the software inventory bi-annually, or more frequently.

Safeguard 2.2: Ensure Authorized Software is Currently Supported

Asset Type: Software	Security Function: Identify	IG1	IG2	IG3
-----------------------------	------------------------------------	------------	------------	------------

Ensure that only currently supported software is designated as authorized in the software inventory for enterprise assets. If software is unsupported, yet necessary for the fulfillment of the enterprise’s mission, document an exception detailing mitigating controls and residual risk acceptance. For any unsupported software without an exception documentation, designate as unauthorized. Review the software list to verify software support at least monthly, or more frequently.

Safeguard 2.3: Address Unauthorized Software

Asset Type: Software	Security Function: Respond	IG1	IG2	IG3
-----------------------------	-----------------------------------	------------	------------	------------

Ensure that unauthorized software is either removed from use on enterprise assets or receives a documented exception. Review monthly, or more frequently.

Safeguard 2.4: Utilize Automated Software Inventory Tools

Asset Type: Software	Security Function: Detect	IG2	IG3
-----------------------------	----------------------------------	------------	------------

Utilize software inventory tools, when possible, throughout the enterprise to automate the discovery and documentation of installed software.

Safeguard 2.5: Allowlist Authorized Software

Asset Type: Software	Security Function: Protect	IG2	IG3
----------------------	----------------------------	-----	-----

Use technical controls, such as application allowlisting, to ensure that only authorized software can execute or be accessed. Reassess bi-annually, or more frequently.

Safeguard 2.6: Allowlist Authorized Libraries

Asset Type: Software	Security Function: Protect	IG2	IG3
----------------------	----------------------------	-----	-----

Use technical controls to ensure that only authorized software libraries, such as specific .dll, .ocx, and .so files, are allowed to load into a system process. Block unauthorized libraries from loading into a system process. Reassess bi-annually, or more frequently.

Safeguard 2.7: Allowlist Authorized Scripts

Asset Type: Software	Security Function: Protect	IG3
----------------------	----------------------------	-----

Use technical controls, such as digital signatures and version control, to ensure that only authorized scripts, such as specific .ps1, and .py files are allowed to execute. Block unauthorized scripts from executing. Reassess bi-annually, or more frequently.

CONTROL 3

Data Protection

Safeguards: 14	IG1: 6/14	IG2: 12/14	IG3: 14/14
----------------	-----------	------------	------------

Overview

Develop processes and technical controls to identify, classify, securely handle, retain, and dispose of data.

Why is this Control critical?

Data is no longer only contained within an enterprise's border; it is in the cloud, on portable end-user devices where users work from home, and is often shared with partners or online services that might have it anywhere in the world. In addition to sensitive data an enterprise holds related to finances, intellectual property, and customer data, there also might be numerous international regulations for protection of personal data. Data privacy has become increasingly important, and enterprises are learning that privacy is about the appropriate use and management of data, not just encryption. Data must be appropriately managed through its entire life cycle. These privacy rules can be complicated for multi-national enterprises of any size; however, there are fundamentals that can apply to all.

Once attackers have penetrated an enterprise's infrastructure, one of their first tasks is to find and exfiltrate data. Enterprises might not be aware that sensitive data is leaving their environment because they are not monitoring data outflows.

While many attacks occur on the network, others involve physical theft of portable end-user devices, attacks on service providers or other partners holding sensitive data. Other sensitive enterprise assets may also include non-computing devices that provide management and control of physical systems, such as Supervisory Control and Data Acquisition (SCADA) systems.

The enterprise's loss of control over protected or sensitive data is a serious and often reportable business impact. While some data is compromised or lost as a result of theft or espionage, the vast majority are a result of poorly understood data management rules, and user error. The adoption of data encryption, both in transit and at rest, can provide mitigation against data compromise, and, even more important, it is a regulatory requirement for most controlled data.

Procedures and tools

It is important for an enterprise to develop a data management process that includes a data management framework, data classification guidelines, and requirements for protection, handling, retention, and disposal of data. There should also be a data breach process that plugs into the incident response plan, and the compliance and communication plans. To derive data sensitivity levels, enterprises need to catalog their key types of data and the overall criticality (impact to its loss or corruption) to the enterprise. This analysis would be used to create an overall data classification scheme for the enterprise. Enterprises may use labels, such as “Sensitive,” “Confidential,” and “Public,” and classify their data according to those labels.

Once the sensitivity of the data has been defined, a data inventory or mapping should be developed that identifies software accessing data at various sensitivity levels and the enterprise assets that house those applications. Ideally, the network would be separated so that enterprise assets of the same sensitivity level are on the same network and separated from enterprise assets with different sensitivity levels. If possible, firewalls need to control access to each segment, and have user access rules applied to only allow those with a business need to access the data.

For more comprehensive treatment of this topic, we suggest the following resources to help the enterprise with data protection:

NIST® SP 800-88r1 Guides for Media Sanitization: <https://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.800-88r1.pdf>

NIST® FIPS 140-2: <https://nvlpubs.nist.gov/nistpubs/FIPS/NIST.FIPS.140-2.pdf>

NIST® FIPS 140-3: <https://nvlpubs.nist.gov/nistpubs/FIPS/NIST.FIPS.140-3.pdf>

For cloud-specific guidance, refer to the CIS Controls Cloud Companion Guide:
<https://www.cisecurity.org/controls/resources?crc=environment-specific-guidance>

For tablet and smart phone guidance, refer to the CIS Controls Mobile Companion Guide:
<https://www.cisecurity.org/controls/resources?crc=environment-specific-guidance>

Safeguards

Safeguard 3.1: Establish and Maintain a Data Management Process

Asset Type: Data	Security Function: Govern	IG1	IG2	IG3
------------------	---------------------------	-----	-----	-----

Establish and maintain a documented data management process. In the process, address data sensitivity, data owner, handling of data, data retention limits, and disposal requirements, based on sensitivity and retention standards for the enterprise. Review and update documentation annually, or when significant enterprise changes occur that could impact this Safeguard.

Safeguard 3.2: Establish and Maintain a Data Inventory

Asset Type: Data	Security Function: Identify	IG1	IG2	IG3
------------------	-----------------------------	-----	-----	-----

Establish and maintain a data inventory based on the enterprise’s data management process. Inventory sensitive data, at a minimum. Review and update inventory annually, at a minimum, with a priority on sensitive data.

Safeguard 3.3: Configure Data Access Control Lists

Asset Type: Data	Security Function: Protect	IG1	IG2	IG3
------------------	----------------------------	-----	-----	-----

Configure data access control lists based on a user’s need to know. Apply data access control lists, also known as access permissions, to local and remote file systems, databases, and applications.

Safeguard 3.4: Enforce Data Retention

Asset Type: Data	Security Function: Protect	IG1	IG2	IG3
------------------	----------------------------	-----	-----	-----

Retain data according to the enterprise’s documented data management process. Data retention must include both minimum and maximum timelines.

Safeguard 3.5: Securely Dispose of Data

Asset Type: Data	Security Function: Protect	IG1	IG2	IG3
------------------	----------------------------	-----	-----	-----

Securely dispose of data as outlined in the enterprise’s documented data management process. Ensure the disposal process and method are commensurate with the data sensitivity.